

ISO/IEC 27001:2022

ISO/IEC 27001:2022 overview

ISO/IEC 27000 family of standards provide a framework for policies and procedures that include legal, physical, and technical controls involved in an organization's information risk management processes. ISO/IEC 27001:2022 is a security standard that formally specifies an Information Security Management System (ISMS) that is intended to bring information security under explicit management control. As a formal specification, it mandates requirements that define how to implement, monitor, maintain, and continually improve the ISMS. It also prescribes a set of best practices that include documentation requirements, divisions of responsibility, availability, access control, security, auditing, and corrective and preventive measures. Certification to ISO/IEC 27001:2022 helps organizations comply with numerous regulatory and legal requirements that relate to information security.

ISO/IEC 27001:2022 specifies the requirements for implementing, maintaining, monitoring, and continually improving the ISMS. ISO/IEC 27002:2022 provides guidelines and best practices for information security management; however, an organization can't get certified against ISO/IEC 27002:2022 because it isn't a management standard. The audit vehicle is ISO/IEC 27001:2022, which relies on detailed guidelines in ISO/IEC 27002:2022 for control implementation.

Azure and ISO/IEC 27001

Microsoft Azure, Dynamics 365, and other Microsoft online services undergo regular independent third-party audits for ISO/IEC 27001 compliance. You can review the Azure ISO/IEC 27001 certificate and audit report for more information.

For extra customer assistance, Microsoft provides the Azure Policy regulatory compliance built-in initiatives for Azure and Azure Government, which map to ISO/IEC 27001 **compliance domains** and **controls**:

- [ISO/IEC 27001 Azure regulatory compliance built-in initiative](#)
- [ISO/IEC 27001 Azure Government regulatory compliance built-in initiative](#)

Regulatory compliance in Azure Policy provides built-in initiative definitions to view a list of controls and compliance domains based on responsibility – customer, Microsoft, or shared. For Microsoft-responsible controls, we provide extra audit result details based on third-party attestations and our control implementation details to achieve that compliance. Each ISO/IEC 27001 control is associated with one or more Azure Policy definitions. These policies may help you [assess compliance](#) with the control; however, compliance in Azure Policy is only a partial view of your overall compliance status. Azure Policy helps to enforce organizational standards and assess compliance at scale. Through its compliance dashboard, it provides an aggregated view to evaluate the overall state of the environment, with the ability to drill down to more granular status.

Applicability

- Azure
- Azure Government
- Azure China (for more information, see [Trust Center](#) [↗](#) documentation)

Services in scope

For a list of Microsoft cloud services in audit scope, see the Azure ISO/IEC 27001 certificate or [Cloud services in audit scope](#):

- Azure
- Dynamics 365
- Microsoft 365
- Power Platform

For Azure DevOps, see the standalone Azure DevOps ISO/IEC 27001 certificate.

Office 365 and ISO/IEC 27001

For more information about Office 365 compliance, see [Office 365 ISO/IEC 27001 documentation](#).

Microsoft Professional Services compliance

For more information about Microsoft Professional Services compliance, see [Microsoft Professional Services documentation](#) [↗](#).

Audit reports and certificates

The Azure ISO/IEC 27001 certificate covers Azure, Dynamics 365, Power Platform, and select Microsoft 365 cloud services. You can access Azure ISO/IEC 27001 audit documents from the Service Trust Portal (STP) [ISO reports](#) section. For instructions on how to access audit reports and certificates, see [Audit documentation](#).

The Azure DevOps ISO/IEC 27001 certificate is available separately from the Service Trust Portal [ISO reports](#) section.

Frequently asked questions

Why is ISO/IEC 27001 certification important?

Compliance with ISO/IEC 27001, certified by an accredited auditor, demonstrates that Azure uses internationally recognized processes and best practices to manage the infrastructure and organization that support and deliver its services. The certificate validates that Microsoft has implemented the guidelines and general principles for initiating, implementing, maintaining, and improving the management of information security.

How can I get the Azure ISO/IEC 27001 audit documentation?

For links to audit documentation, see [Audit reports and certificates](#).

Can I use the Azure ISO/IEC 27001 compliance assurances in my organization's certification process?

Yes. If your business is seeking certification for an implementation deployed using in-scope services, you can use the relevant Azure certifications in your compliance assessment. However, you're responsible for engaging an assessor to evaluate your implementation for compliance and for the controls and processes within your own organization.

What resources does Microsoft provide to help customers with their certification process?

Aside from the Azure ISO/IEC 27001 audit report and certificate, Microsoft provides the Azure Policy regulatory compliance built-in initiatives for [Azure](#) and [Azure Government](#), which map to ISO/IEC 27001 compliance domains and controls. Azure Policy helps to enforce organizational standards and assess compliance at scale.

Resources

- [Azure compliance documentation](#)
 - [Azure enables a world of compliance](#) 
 - [Microsoft 365 compliance offerings](#)
 - [Compliance on the Microsoft Trust Center](#) 
 - Microsoft [Product Terms](#)  (formerly Online Services Terms)
 - Microsoft Products and Services [Data Protection Addendum](#)  (DPA)
 - [13 Effective Security Controls for ISO 27001 Compliance](#) 
 - [ISO/IEC 27001:2022](#)  (available for purchase)
 - [ISO/IEC 27002:2022](#)  (available for purchase)
-

Last updated on 05/26/2023